

A3-PS004-TC136

Authenticated Gateway-Assisted DNSSEC for IoT Clients

1. Arsh Sanghavi
arshssanghavi@proton.me

2. Mentor: Prof. Erukala Suresh Babu
esbabu@nitw.ac.in

Team ASTRO • NIT Warangal

AIORI Hackathon 3

October 14, 2026

Problem Description

IoT devices need DNSSEC protection but cannot afford to validate it themselves.

- DNSSEC stops spoofing, but checking signatures costs memory, CPU and battery a microcontroller lacks. Without it, a device looking up its OTA or MQTT server can be redirected.
- PS-004 idea: the device hands validation to a trusted local gateway over an authenticated, encrypted channel (e.g. TLS or DTLS).
- Safe only if the device rejects bogus answers *and* refuses unauthenticated gateways; the AD bit alone is just a header flag.
- Goal: measure the device-side cost (latency, CPU, memory) against a baseline, for secure, insecure and bogus answers.
- The device does not validate itself, so protection ends at the gateway; no end-to-end DNSSEC claim.

Background

Three pieces we build on

- **DNSSEC validation** [1, 2]: a validator follows DS/DNSKEY/RRSIG from a trust anchor and labels each answer secure, insecure (no DS, legitimately unsigned) or bogus (signatures fail). Bogus becomes SERVFAIL. Per RFC 6840 [3], a stub may trust the AD bit only over a channel it trusts.
- **Telling the client why:** Extended DNS Errors [4] attach a reason to SERVFAIL, e.g. 6 *DNSSEC Bogus*, 7 *Signature Expired*, 9 *DNSKEY Missing*.
- **Securing the last hop:** DNS over TLS [5] on port 853, or DNS over CoAP [6] (RFC, March 2026) protected by DTLS or OSCORE [7], which encrypts each CoAP message without a full handshake.

Literature & RFC Review

What exists, and what it leaves open

Work	Relevance to us
RFC 4033 / 4035 [1, 2]	Validation states and the AD bit; the reference this problem cites
RFC 6840 [3]	AD bit is only meaningful over a secure path to a trusted validator
RFC 8914 [4]	Extended DNS Errors: the device can log *why* a lookup failed
RFC 7858 / 9325 [5, 9]	DNS over TLS and current TLS settings for that path
RFC 9953 / 8613 [6, 7]	DNS over CoAP with OSCORE: encrypted DNS sized for constrained nodes
Lenders et al., CoNEXT 2023 [8]	DoC vs. DNS over UDP and DTLS on RIOT; OSCORE saves over 10 kB of code vs. DTLS. **No DNSSEC validation or bogus-answer testing.**

Questions we answer: (1) What does delegated validation cost the device over TLS vs. OSCORE, cold and warm? (2) Can the device stay safe against *downgrade* to unsigned answers, not only against bogus ones?

Proposed Solution

Let a trusted gateway validate, and make the device strict about what it accepts from it

- **Validating gateway:** checks every answer against a trust anchor for our own test domain [10], signed in secure, insecure and bogus variants.
- **Authenticated channel, two ways:** DNS over TLS with mutual authentication, or DNS over CoAP with OSCORE. The gateway identity is fixed on the device, so an impostor is refused.
- **Lightweight device:** ESP32-S3 with no DNSSEC code; trusts only verdicts from the authenticated channel and fails closed without it.
- **Actionable verdicts:** failures carry an Extended DNS Error code, so the device knows *why* a lookup was refused.
- **Critical names must be secure:** an unsigned answer for the update or MQTT server is refused (no silent downgrade).
- **Evaluation:** both channels vs. plain DNS and on-device validation, under spoofing and rogue-gateway attacks.

Optimization Proposed

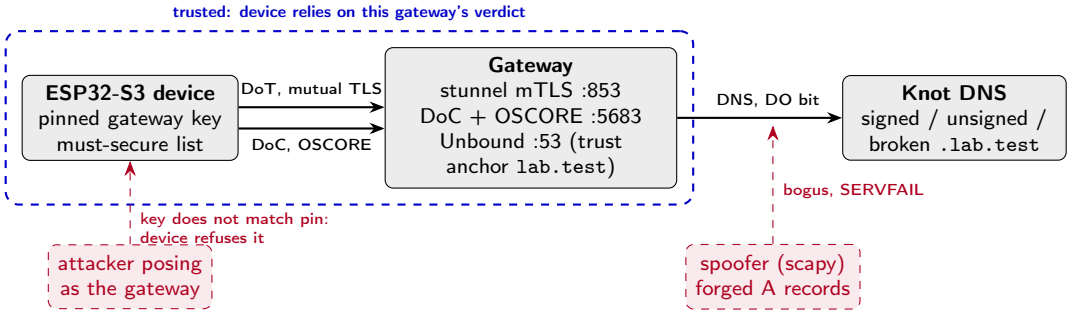
Before vs. after, per lookup on the device

	Plain DNS	On-device valid.	Gateway + DoT	Gateway + DoC
Spoofed answer	accepted	rejected	rejected	rejected
Fake resolver / gateway	accepted	data rejected	refused (mTLS)	refused (OSCORE)
Unsigned critical name	accepted	accepted	rejected	rejected
Handshake per lookup	none	none	once, then resumed	none
Flash / RAM	smallest	largest	TLS stack	below DTLS? [8]

Measured on the ESP32-S3: latency and CPU (`esp_timer`), peak heap (heap stats), flash (size report), bytes on air (Wireshark). 50 runs per case, cold and warm, median and p95. Energy only with an INA219.

Solution Architecture & Design

Lab setup and the trust boundary



Trust ends at the gateway: the device does not validate DNSSEC itself, so we make no end-to-end claim. Full threat model on the next slide. *Figure: System architecture.*

Threat Model & Trust Boundary

Each threat, what stops it, and what is left

Threat	Stopped by	What remains
Forged upstream answer	gateway DNSSEC validation	none, if trust anchor is correct
Fake gateway (evil twin, ARP)	pinned key (mTLS / OSCORE)	none, while key is secret
Eavesdropping, tampering	TLS / OSCORE protection	timing and size metadata
Replay of old response	TLS sequence / OSCORE window	none
Downgrade on critical name	must-be-secure list	unlisted names
Unauthorised device	client cert / OSCORE key	key theft (flash encryption)
Gateway offline	device fails closed	availability only
Compromised gateway	**not defended**	stated non-goal

Protection ends at the gateway; no end-to-end DNSSEC claim [3].

Data Flow Diagram

One lookup, from the device's point of view

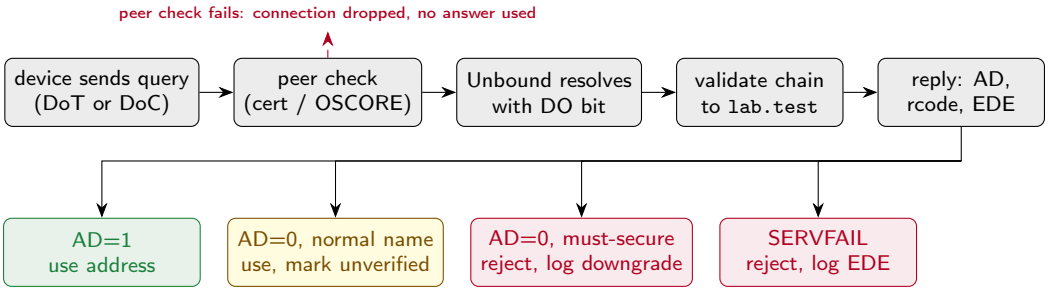


Figure: Data Flow Diagram (DFD)

Verification Matrix

Eight scenarios, each run over both DoT and DoC/OSCORE

	Scenario	How we produce it	Device receives	Verdict
1	Secure answer	`signed.lab.test`	AD=1	accept
2	Insecure, normal name	`unsigned.lab.test`	AD=0	accept, flagged
3	Insecure, critical name	OTA name in unsigned zone	AD=0	reject (downgrade)
4	Bogus signature	corrupted RRSIG	SERVFAIL, EDE 6	reject, logged
5	Expired signature	RRSIG past expiry	SERVFAIL, EDE 7	reject, logged
6	Forged upstream answer	scapy injection	SERVFAIL	reject
7	Fake gateway	key not matching pin	handshake fails	no answer used
8	Unauthorised device	no cert / OSCORE key	refused	no service

Pass: expected verdict in every run; for 4–5 the logged reason must match the injected fault. All 16 cases scripted for the demo.

Deployment Timeline

Plan against the hackathon dates

2026	Work
by 14 Oct	Repo, this deck, team video
16–20 Oct	ESP-IDF toolchain on the ESP32-S3; Knot zones signed; Unbound validating; all three zones checked with `dig +dnssec`
21–25 Oct	stunnel mTLS and DoC/OSCORE proxy; device firmware for both paths; plain-DNS baseline
26–31 Oct	Spoofer and rogue-gateway tests; benchmarks; try on-device validation as the second baseline; code pushed
31 Oct–4 Nov	Report with threat model; recorded demo of the three attacks being rejected
24–30 Nov	Regional round, if selected

Fallback: if DoC/OSCORE slips, the DoT path alone still covers the required results.

Bibliography

[1] R. Arends et al. *DNS Security Introduction and Requirements*. RFC 4033, 2005.

[2] R. Arends et al. *Protocol Modifications for the DNS Security Extensions*. RFC 4035, 2005.

[3] S. Weiler, D. Blacka. *Clarifications and Implementation Notes for DNS Security (DNSSEC)*. RFC 6840, 2013.

[4] W. Kumari et al. *Extended DNS Errors*. RFC 8914, 2020.

[5] Z. Hu et al. *Specification for DNS over Transport Layer Security (TLS)*. RFC 7858, 2016.

[6] M. S. Lenders et al. *DNS over CoAP (DoC)*. RFC 9953, 2026.

[7] G. Selander et al. *Object Security for Constrained RESTful Environments (OSCORE)*. RFC 8613, 2019.

[8] M. S. Lenders et al. Securing Name Resolution in the IoT: DNS over CoAP. *Proc. ACM Netw.* 1(CoNEXT2), 2023. doi:10.1145/3609423

[9] Y. Sheffer, P. Saint-Andre, T. Fossati. *Recommendations for Secure Use of TLS and DTLS*. RFC 9325, 2022.

[10] S. Cheshire, M. Krochmal. *Special-Use Domain Names*. RFC 6761, 2013.

Thank You for Your Attention!